Security Requirements Table — Bank Management System

Actors: Customer, Bank Employee, System Administrator

Security ID	Category	Security Requirement / Description	Priority	Acceptance Criteria	Rationale
SEC-01	Authentication	Session-Based Authentication: Users must authenticate with valid credentials before accessing protected resources. The system issues cryptographically signed HttpOnly, SameSite cookies.	High	Pass: Valid login creates a signed session; invalid credentials are rejected; sessions are immediately invalidated upon logout. Fail: Protected routes are accessible without a session, or session cookies lack HttpOnly flags.	Prevents unauthorized users and automated scripts from accessing banking functions.
SEC-02	Credential Protection	Cryptographic Password Hashing: User passwords must never be stored, transmitted, or logged in plain text. Passwords must be hashed using bcrypt with random per-user cryptographic salts.	High	Pass: Database stores only salted bcrypt hashes with cost factor 12. Fail: Plain-text passwords appear in database tables, log files, or API responses.	Protects user credentials against credential harvesting if database storage is compromised.
SEC-03	Threat Mitigation	Brute-Force Rate Limiting: The system must enforce automatic lockout controls on repeated authentication failures to mitigate automated credential guessing.	High	Pass: 5 consecutive failed login attempts trigger a 15-minute account lockout; subsequent attempts within the lockout window are rejected with clear status. Fail: Unlimited login attempts are permitted without throttling.	Mitigates automated dictionary attacks and credential stuffing campaigns against user accounts.
SEC-04	Session Defense	Cross-Site Request Forgery Defense: All mutating HTTP requests (POST, PUT, DELETE) must validate a secure per-session anti-CSRF token supplied via the X-CSRF-Token header.	High	Pass: State-changing requests succeed only with a valid CSRF token; missing or forged tokens return HTTP 403 Forbidden. Fail: Mutating requests succeed without CSRF token validation.	Prevents malicious external websites from executing unauthorized banking actions on behalf of authenticated users.
SEC-05	Access Control	Role-Based Access Control: Server-side guards must enforce strict role boundaries restricting Customer, Employee, and Admin operations.	High	Pass: Each role accesses only permitted functions; Customer cannot access Employee queue or Admin backup; Employee cannot access Admin backup or audit logs. Fail: Privileged endpoints can be invoked by lower-privileged roles.	Prevents vertical privilege escalation and limits administrative powers to verified administrators.
SEC-06	Access Control	Horizontal Ownership Isolation: The system must verify that the authenticated user owns the requested account, beneficiary, loan, or profile record before reading or modifying data.	High	Pass: Requests for records belonging to another customer return HTTP 403 Forbidden or 404 Not Found. Fail: A customer can read balances, view histories, or execute transfers on another customer account.	Protects customer privacy and prevents horizontal data leaks between different bank customers.
SEC-07	Input Validation	Input Sanitization and SQL Injection Defense: All API inputs must be validated on the server for positive values, expected patterns, and bound via parameterized SQL queries.	High	Pass: Negative amounts, zero amounts, malformed account strings, and SQL injection payloads are rejected safely; queries execute via SQLite parameter bindings. Fail: Malicious SQL fragments alter query execution or change unauthorized data.	Prevents SQL injection and prevents corrupt or negative values from entering the banking ledger.
SEC-08	Financial Integrity	Atomic Processing and Rollback: All financial operations affecting multiple accounts must execute within an isolated ACID database transaction.	High	Pass: Both sender debit and recipient credit commit together, or both roll back on any mid-operation failure. Fail: A failed transfer leaves money debited from sender without reaching recipient.	Prevents partial transfers, race conditions, and ledger discrepancies during system faults.

Security ID	Category	Security Requirement / Description	Priority	Acceptance Criteria	Rationale
SEC-09	Financial Integrity	Currency Precision and Overdraft Enforcement: Balances and transaction amounts must be handled using integer paise to prevent precision loss, and withdrawals must enforce available balance limits.	High	Pass: All balances use integer paise (1 INR = 100 paise); overdraft withdrawals are rejected with HTTP 400 Insufficient funds. Fail: Floating-point rounding discrepancies occur, or an account balance drops below zero without credit authorization.	Eliminates floating-point rounding errors and protects bank solvency by preventing unauthorized overdrafts.
SEC-10	Network Security	Defense-in-Depth HTTP Response Headers: All HTTP responses must include strict security headers and browser caching instructions for sensitive banking data.	Medium	Pass: Responses include Content-Security-Policy, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, and Cache-Control: no-store, no-cache. Fail: Security headers are omitted or sensitive data is cached by public proxy servers.	Mitigates clickjacking, cross-site scripting (XSS), MIME-type sniffing, and sensitive data leakage via shared browser caches.
SEC-11	Client Protection	Spreadsheet Formula Injection Prevention: Tabular CSV statement exports must sanitize all cells beginning with formula trigger characters (=, +, -, @).	Medium	Pass: Exported CSV cells starting with formula characters are prepended with an apostrophe to neutralize execution in Excel or Calc. Fail: Raw formulas execute commands or leak data when customer opens exported statement in spreadsheet software.	Neutralizes CSV injection vulnerabilities where malicious account descriptions or notes trigger local command execution.
SEC-12	Accountability	Immutable Audit Trail Logging: Security-relevant events (authentication, access violations, account creation, fund transfers, loan decisions, and administrative actions) must be recorded in an immutable audit log.	High	Pass: Audit log records actor ID, role, action, target entity, client IP address, and UTC timestamp; records cannot be updated or deleted through the application. Fail: Sensitive actions occur without logging, or audit records can be modified by users.	Provides non-repudiation, forensics capability, and regulatory compliance verification.
SEC-13	Data Protection	Database Snapshot Cryptographic Verification: Online SQLite database backups must be verified using SHA-256 cryptographic hashes and internal consistency checks.	Medium	Pass: Created backups compute and store SHA-256 checksums; backup integrity verification executes PRAGMA integrity check and validates matching hashes. Fail: Corrupted, truncated, or tampered backup files are reported as valid.	Ensures backup archives remain authentic and usable before disaster recovery restoration is attempted.
SEC-14	Data Protection	Disaster Recovery with Pre-Restore Snapshot: Database restoration must create a safety checkpoint of the live database prior to applying a verified backup snapshot.	Medium	Pass: Pre-restore safety snapshot is created automatically; restore applies only verified backups; aborted restorations leave live database intact. Fail: Database restore corrupts live database or overwrites data without safety fallback.	Mitigates permanent data loss during administrative maintenance and recovery operations.
SEC-15	Availability	Database Lock Handling and Fault Isolation: The system must configure SQLite busy timeout handlers and enforce connection teardown rollbacks on unhandled errors.	Medium	Pass: Concurrent requests wait up to busy timeout without crashing; failed requests trigger automated connection rollback; service health check reports database liveness. Fail: Concurrent requests trigger locked database exceptions that crash the API process.	Ensures service availability and prevents persistent database locks from degrading banking operations.